

ALPINE

DUE DILIGENCE

Compliance Policy Manual

Version 2.0 - Revised Edition

ORGANIZATION	Alpine Due Diligence Inc.
DOCUMENT TYPE	Consolidated Compliance Policies
VERSION	2.0
SUPERSEDES	Version 1.0 (February 15, 2026)
EFFECTIVE DATE	April 27, 2026
NEXT REVIEW	April 27, 2027
OWNER	Allen Zhang, Founder & CEO
CLASSIFICATION	Confidential

Introduction

This Compliance Policy Manual is the single consolidated reference for all information security, privacy, and compliance policies governing Alpine Due Diligence Inc. ("Alpine"). It is designed to be provided to clients, auditors, and regulators as evidence of Alpine's formal security program.

This manual encompasses all policies required for Alpine's compliance posture, including client-facing policies (Privacy Policy, Terms of Service, Security Overview), internal governance policies (Information Security, Data Classification, Incident Response, Change Management, Acceptable Use, Vendor Management, Business Continuity), and legal templates (Data Processing Agreement, Risk Assessment).

All employees, contractors, and authorized users with access to Alpine systems are required to read this manual in its entirety and sign the Policy Acknowledgment Form (Appendix N). The signed form must be returned to azhang@alpinedd.com within 5 business days of receiving system access. Annual re-acknowledgment is required upon each revision of this manual.

[v2.0 Update: Version 2.0 revises infrastructure descriptions, vendor inventory, BCP RTO, and organizational roles.]

Document Control

Field	Value
Version	2.0
Effective Date	April 27, 2026
Supersedes	Version 1.0 - February 15, 2026
Next Scheduled Review	April 27, 2027
Document Owner	Allen Zhang, Founder & CEO
Classification	Confidential
Distribution	Authorized personnel, clients, and auditors

Summary of Changes from v1.0

Section	Change
Appendix A - Privacy Policy	Updated infrastructure: application server (Hetzner) vs. database (Supabase/AWS)
Appendix C - Security Overview	Corrected infrastructure diagram; added Supabase and Cloudflare
Appendix D - Info Security Policy	Updated organizational roles to reflect current team structure
Appendix J - Vendor Management	Added Supabase (database) and Resend (email) to approved vendor inventory
Appendix K - Business Continuity	Revised RTO to reflect realistic solo-founder recovery capabilities; added escalation path
Appendix M - Risk Assessment	Added Supabase data exposure risk; updated founder risk mitigations

Appendix Index

Appendix	Policy	Category
A	Privacy Policy	Client-facing
B	Terms of Service	Client-facing

C	Security Overview	Client-facing
D	Information Security Policy	Internal
E	Data Classification & Handling	Internal
F	Data Retention & Disposal	Internal
G	Incident Response Plan	Internal
H	Change Management Policy	Internal
I	Acceptable Use Policy	Internal
J	Vendor Management Policy	Internal
K	Business Continuity Plan	Internal
L	Data Processing Agreement	Legal
M	Risk Assessment	Legal
N	Policy Acknowledgment Form	Required

Appendix A: Privacy Policy

Effective Date: April 27, 2026 | Last Updated: April 27, 2026 | Published at: alpinedd.com/privacy

1. Introduction

Alpine Due Diligence Inc. ("Alpine," "we," "our," or "us") operates an AI-powered operational due diligence analysis platform at alpinedd.com (the "Service"). This Privacy Policy describes how we collect, use, store, and protect information when you use our Service. We are committed to protecting the confidentiality and security of all information entrusted to us by our clients.

2. Information We Collect

2.1 Account Information

Name, email address, and organizational affiliation provided during account registration. Authentication credentials (passwords are stored using industry-standard bcrypt hashing; Alpine never stores plaintext passwords). Role and permission assignments configured by your organization.

2.2 Uploaded Documents

Fund documents, DDQs, regulatory filings, and other materials uploaded by authorized users for analysis. All uploaded documents are treated as Confidential data.

2.3 Generated Content

Analysis reports, risk assessments, and other outputs produced by the Service. User annotations, comments, and custom configurations applied to reports.

2.4 Usage Logs

Timestamps, IP addresses, and browser metadata associated with platform access. Feature usage patterns and performance telemetry (anonymized and aggregated).

3. How We Use Your Information

- **Analysis Only:** Uploaded documents are processed solely to generate due diligence reports. Documents are never used for marketing or any unrelated purpose.
- **Service Improvement:** Anonymized, aggregated benchmarking data may be used to improve analytical frameworks. No client-identifiable data is included.
- **Security & Compliance:** Usage logs are retained to support audit trails, incident investigation, and regulatory compliance.

4. How We Store and Protect Your Data

[v2.0 Update: Infrastructure updated: application server (Hetzner) and database (Supabase/AWS) are now separately described.]

Alpine's infrastructure consists of two components:

Application Server: The Alpine web application is hosted on a dedicated server provided by Hetzner Online GmbH (ISO 27001 certified), located in the European Union. The application server handles request routing, authentication, and report rendering.

Database & Storage: Client data (report drafts, notes, uploaded documents, and related records) is stored in

Supabase, a managed database service whose infrastructure runs on Amazon Web Services (AWS). Data is encrypted at rest (AES-256) and in transit (TLS 1.3) within Supabase infrastructure. A Data Processing Agreement (DPA) is in place with Supabase.

All communications between your browser and Alpine servers use TLS 1.3. Role-based access control (RBAC) and JWT-based authentication protect all access. Every access event is logged.

5. Data Retention

Data Type	Retention Period	Disposal
Uploaded documents	Engagement + 90 days	Secure overwrite
Generated reports	Duration of engagement	Deleted on request
Audit logs	1 year minimum	Archived, then deleted
Account data	Account duration + 30 days	Database deletion
Anonymized benchmarks	Indefinite	N/A (no PII)
Backups	30 days rolling	Encrypted overwrite

6. Third-Party Data Processing

Alpine uses the Anthropic API (Claude) for AI-powered document analysis under a Data Processing Agreement (DPA) with Zero Data Retention (ZDR) - document text sent for analysis is not stored by Anthropic after the API response.

Alpine uses Supabase for database and file storage. Processing is governed by a DPA executed with Supabase Inc.

Alpine uses Resend for transactional email delivery. Email content in transit is subject to Resend's DPA.

No other third parties receive or have access to client document content.

7. Your Rights

- Access: You may request a summary of the personal data we hold about you.
- Deletion: You may request deletion of your data at any time. Alpine will complete deletion within 30 business days and send a written confirmation.
- Portability: You may request export of your uploaded documents and generated reports.
- Opt-Out: You may opt out of anonymized benchmarking by contacting us.

8. Contact

For privacy inquiries, data requests, or complaints:

Email: azhang@alpinedd.com

Alpine Due Diligence Inc.

Appendix B: Terms of Service

Effective Date: April 27, 2026 | Published at: alpinedd.com/terms

1. Service Description

Alpine Due Diligence Inc. ("Alpine") provides an AI-powered operational due diligence (ODD) analysis platform (the "Service"). The Service enables institutional investors and their advisors to upload fund documentation, perform automated gap analysis, generate structured ODD reports, and conduct independent verification checks.

2. Account Responsibilities

- You are responsible for maintaining the confidentiality of your account credentials.
- You must not share login credentials with unauthorized individuals.
- You must use the Service only for authorized business purposes.
- You must notify Alpine immediately of any suspected unauthorized access to your account.

3. Data Ownership

Client Data: You retain all ownership rights to documents you upload and any data you provide. Alpine acquires no ownership interest in client data.

Alpine IP: Alpine retains ownership of its analytical frameworks, methodologies, scoring algorithms, software, and platform infrastructure.

Report License: You receive a non-exclusive, non-transferable license to use reports generated by the Service for your internal business purposes.

4. Limitation of Liability

THE SERVICE PROVIDES ANALYTICAL OUTPUTS TO SUPPORT YOUR DUE DILIGENCE PROCESSES. ALPINE DOES NOT PROVIDE INVESTMENT ADVICE, LEGAL ADVICE, TAX ADVICE, OR ACCOUNTING ADVICE.

To the maximum extent permitted by law, Alpine's total liability for any claims shall not exceed the fees paid by you to Alpine in the twelve (12) months preceding the claim.

5. Confidentiality

Alpine treats all client data as confidential. We will not disclose client data to third parties except as necessary to provide the Service, as required by law, or with your written consent.

6. Termination

Either party may terminate the Service agreement with 30 days' written notice. Upon termination, Alpine will delete all client data within 30 days, unless retention is required by law.

7. Disclaimer

THE SERVICE IS PROVIDED "AS IS" AND "AS AVAILABLE." ALPINE MAKES NO WARRANTIES,

EXPRESS OR IMPLIED. Alpine does not guarantee the accuracy, completeness, or timeliness of any analysis output. Users should independently verify all findings before making investment decisions.

8. Governing Law

These Terms shall be governed by and construed in accordance with applicable law. Any disputes shall be resolved through binding arbitration.

Appendix C: Security Overview

This document provides a high-level overview of Alpine's security architecture and controls.

[v2.0 Update: Infrastructure architecture updated to reflect two-tier design: Hetzner app server + Supabase/AWS database.]

Data Flow Architecture

All client data follows a controlled, auditable path through the Alpine platform:

Client Browser -> Alpine App Server (Hetzner, EU) -> Anthropic API (analysis)
Alpine App Server -> Supabase Database (AWS) -> Client Browser

TLS 1.3 encryption protects data in transit at every stage. The Anthropic API processes document text transiently under Zero Data Retention (ZDR) terms. Supabase stores persistent data (drafts, notes, documents) under AES-256 encryption at rest.

Infrastructure Components

Component	Provider	Purpose	Certification
Application Server	Hetzner Online GmbH (EU)	Web app, routing, auth	ISO 27001
Database & Storage	Supabase / AWS	Persistent client data	SOC 2 Type II (AWS)
AI Analysis	Anthropic API	Document analysis (transient)	SOC 2 Type II
CDN / DDoS	Cloudflare	Edge delivery, DDoS protection	SOC 2 Type II
Email Delivery	Resend	Transactional email	SOC 2

Encryption Standards

Layer	Standard	Details
In Transit	TLS 1.3	All API and browser connections
At Rest	AES-256	Supabase database encryption + Hetzner disk encryption
Backups	AES-256	Encrypted daily automated backups
Passwords	bcrypt	Salted + hashed, never stored plaintext

Access Controls

- Role-Based Access Control (RBAC): Users are assigned roles with granular permissions.
- JWT Authentication: Stateless, cryptographically signed session tokens with expiry.
- Session Management: Automatic timeout after inactivity. Concurrent session limits.
- Account Lockout: Accounts locked after 5 consecutive failed login attempts.
- Audit Logging: Every access event logged with timestamp, user identity, IP, and action.

AI Data Handling

- Alpine uses Anthropic's Commercial API, which explicitly prohibits training on customer data.
- A Data Processing Agreement (DPA) is in place with Anthropic.

- Zero Data Retention (ZDR) is enabled: API inputs and outputs are not stored by Anthropic.
- No client data is used for model training, fine-tuning, or any purpose beyond generating the requested analysis.

Compliance Roadmap

Milestone	Target Date	Status
NIST CSF 2.0 Alignment	Q1 2026	Completed
SOC 2 Type I Audit	Q3 2026	In Progress
Penetration Test	Q3 2026	In Progress
Supabase DPA Execution	Q2 2026	Completed
SOC 2 Type II Audit	Q1 2027	Planned

Appendix D: Information Security Policy

Owner: Allen Zhang, Founder & CEO | Review Cycle: Annual

[v2.0 Update: Organizational roles updated to reflect current team structure beyond solo-founder stage.]

1. Purpose

This policy establishes the framework for protecting the confidentiality, integrity, and availability of all information assets owned, processed, or managed by Alpine Due Diligence Inc. It applies to all Alpine systems, data, personnel, and contractors.

2. Scope

This policy applies to all Alpine information systems, networks, applications, data repositories, and cloud services, as well as all personnel, contractors, and third parties who access Alpine systems or data.

3. Roles and Responsibilities

Alpine is in an early growth stage. The Founder currently holds primary security responsibilities, with plans to delegate as the team scales. All team members share responsibility for following this policy within their scope of access.

Role	Responsibility	Current Holder
Security Lead	Overall security program ownership and incident response	Allen Zhang (Founder & CEO)
System Admin	Server hardening, patching, monitoring (Hetzner + Supabas)	Allen Zhang (Founder & CEO)
Data Owner	Data classification and access decisions	Allen Zhang (Founder & CEO)
CCO (future hire)	Compliance oversight, audit liaison, annual policy review	TBD - hire planned
Team Members	Comply with all policies; report incidents immediately	All current team members

Note: As Alpine scales beyond the founding stage, security responsibilities will be progressively delegated. Each team member is individually accountable for the data and systems they access. Compensating controls during the growth period include audit logging, documented self-review procedures, and annual policy re-acknowledgment.

4. Data Classification

All Alpine data is classified into one of three categories. See Appendix E for full handling procedures.

Classification	Description	Examples
Public	No sensitivity; freely shareable	Website, marketing, published policies
Internal	Business-sensitive; internal only	Source code, architecture, strategy
Confidential	Highly sensitive; restricted access	Client docs, reports, user data, API keys

5. Access Control Principles

- **Least Privilege:** Users receive only the minimum permissions required for their role.
- **Need-to-Know:** Access to Confidential data is granted only when required for a specific business function.
- **Separation of Duties:** Where feasible, no single individual controls all aspects of a critical process.

- Authentication: All access requires strong authentication. Multi-factor authentication (MFA) is required for all administrative access.

6. Incident Management

All security incidents must be reported, assessed, and resolved according to the Incident Response Plan (Appendix G). Affected clients will be notified within 72 hours of a confirmed data breach.

7. Policy Review

This policy and all appendices will be reviewed at least annually, or sooner if triggered by a significant security incident, change in business operations, or regulatory update.

Appendix E: Data Classification & Handling

1. Purpose

This policy defines data classification levels and the specific handling, storage, transmission, and disposal requirements for each level.

2. Classification Levels

2.1 Public - Information intended for public consumption. No confidentiality requirements. Examples: website content, published policies, marketing materials.

2.2 Internal - Information intended for use within Alpine only. Disclosure could cause minor business impact. Examples: source code, architecture documentation, business strategy.

2.3 Confidential - Highly sensitive information whose unauthorized disclosure could cause significant harm to Alpine or its clients. Examples: client-uploaded documents, generated ODD reports, user account data, API keys.

3. Handling Requirements

Requirement	Public	Internal	Confidential
Encryption at Rest	Not required	Required	Required (AES-256)
Encryption in Transit	Recommended	Required (TLS)	Required (TLS 1.3)
Access Control	None	Auth required	RBAC + need-to-know
Audit Logging	Not required	Recommended	Required (all access)
Backup	Not required	Standard backup	Encrypted backup
Disposal	Standard delete	Secure delete	Secure overwrite + log

Appendix F: Data Retention & Disposal

1. Retention Schedule

Data Type	Retention Period	Disposal Method
Uploaded client documents	Engagement + 90 days	Secure deletion (overwrite)
Generated reports	Duration of engagement	Secure deletion on request
Audit logs	1 year minimum	Archived, then secure deletion
User account data	Account + 30 days	Database deletion
Anonymized benchmarks	Indefinite	N/A (no client-identifiable data)
Backups	30 days rolling	Encrypted overwrite
Session tokens	24 hours	Automatic expiry + deletion

2. Client Deletion Requests

Clients may request deletion of their data at any time by contacting azhang@alpinedd.com. Alpine will:

1. Acknowledge the request within 2 business days.
2. Complete deletion from primary systems within 30 business days.
3. Confirm deletion in writing to the requesting client.
4. Backup copies will age out within the rolling 30-day backup window.

Appendix G: Incident Response Plan

1. Severity Classification

Severity	Description	Response Time	Example
P1 Critical	Active breach of client data	Immediate	Unauthorized data exfiltration
P2 High	System compromise, no data loss	< 4 hours	Server intrusion detected
P3 Medium	Vulnerability found, unexploited	< 24 hours	Unpatched CVE on server
P4 Low	Minor security event	< 72 hours	Brute-force login attempts blocked

2. Response Phases

- Phase 1 - Detection: Automated monitoring, user reports, external vendor alerts.
- Phase 2 - Assessment: Determine scope, classify severity, document initial findings.
- Phase 3 - Containment: Revoke compromised credentials; isolate affected systems; preserve evidence.
- Phase 4 - Eradication: Remove root cause; reset credentials; verify through log review.
- Phase 5 - Recovery: Restore from clean backups; verify integrity; implement additional monitoring.
- Phase 6 - Notification: Notify clients within 72 hours of confirmed breach; regulators as required by law.
- Phase 7 - Post-Incident Review: Root cause analysis within 5 business days; update controls and policies.

3. Emergency Contacts

Contact	Role	Method
Allen Zhang	Security Lead / Founder	Phone + Email
Hetzner Support	Infrastructure provider	Support portal + phone
Supabase Support	Database provider	Support portal
Anthropic Support	AI API provider	Support portal

Appendix H: Change Management Policy

1. Standard Changes

- All code changes are committed through Git version control. No direct edits to production systems.
- Code review is required before merge. Self-review with documented summary is acceptable for solo work.
- Testing must be performed before deployment: manual smoke test of the critical user flow.
- Deployment: git pull on production server, restart affected services, execute smoke test, verify via monitoring.
- All deployments are logged with date, time, commit hash, and summary of changes.

2. Rollback Procedure

- Identify the issue and the commit that introduced it.
- Execute git revert to reverse the problematic changes.

- Restart affected services and run smoke test.
- Document the rollback event, root cause, and follow-up actions.

3. Emergency Changes

In the event of a critical vulnerability or production outage, the standard change process may be abbreviated, but all changes must still go through Git and be fully documented within 24 hours.

Appendix I: Acceptable Use Policy

1. Acceptable Use

Alpine systems, applications, and data are to be used solely for authorized business purposes related to Alpine's operations and client engagements.

2. Prohibited Activities

- Sharing account credentials with any other person, including colleagues.
- Downloading, copying, or transferring client data to personal devices or unauthorized storage.
- Accessing client data without a legitimate business justification.
- Attempting to bypass, disable, or circumvent any security control.
- Using Alpine systems for any illegal, fraudulent, or unauthorized purpose.
- Installing unauthorized software on Alpine infrastructure.
- Disclosing confidential information to unauthorized parties.

3. Reporting Obligations

All users must report any suspected or actual security incident, policy violation, or unauthorized access immediately to the Security Lead (azhang@alpinedd.com). Failure to report known incidents is itself a policy violation.

Appendix J: Vendor Management Policy

[v2.0 Update: Supabase and Resend added to approved vendor inventory.]

1. Vendor Evaluation Criteria

- Security certifications (SOC 2, ISO 27001, or equivalent).
- Data processing agreement (DPA) availability and terms.
- Data residency and jurisdictional compliance.
- Incident notification and breach response commitments.
- Encryption and access control capabilities.
- Business continuity and disaster recovery provisions.

2. Approved Vendor Inventory

Vendor	Service	Data Access	Certifications	DPA
Anthropic	AI API	Doc text (transient, ZDR)	SOC 2 Type II	Yes + ZDR
Hetzner	App server hosting	Application layer only	ISO 27001	Yes
Supabase	Database & storage	All persistent data (enc.)	SOC 2 (AWS)	Yes
Resend	Transactional email	Email content in transit	SOC 2	Yes
Cloudflare	CDN / DDoS protection	Request metadata only	SOC 2 Type II	Yes
Let's Encrypt	SSL certificates	None	N/A	N/A
GitHub	Code repository	Source code only	SOC 2 Type II	Yes

3. Supabase - Additional Notes

Supabase serves as Alpine's primary database and file storage provider. All persistent client data - including report drafts, analysis notes, ratings, and uploaded documents - resides in Supabase. Supabase's infrastructure runs on Amazon Web Services (AWS). A Data Processing Agreement has been executed with Supabase Inc. Data is encrypted at rest (AES-256) and in transit (TLS 1.3) within Supabase infrastructure. Supabase is reviewed annually as part of the standard vendor review cycle.

4. Ongoing Vendor Monitoring

- All vendors are reviewed annually for continued compliance with Alpine's security requirements.
- Vendors must notify Alpine of any material changes to their security posture.
- Vendor certifications are reviewed upon renewal or when updated versions are issued.
- Any vendor security breach that may affect Alpine data triggers an immediate review.

Appendix K: Business Continuity Plan

[v2.0 Update: RTO revised to reflect realistic recovery timeline; founder-unavailability section expanded.]

1. Recovery Objectives

Objective	Target	Description
RTO (Recovery Time)	8 hours	Maximum time to restore services under normal conditions
RPO (Recovery Point)	24 hours	Maximum acceptable data loss

Note on RTO: An 8-hour RTO is achievable when the Security Lead is available and responsive. In a founder-unavailability scenario, recovery is dependent on documented runbooks and may extend beyond 8 hours. Alpine is actively documenting all recovery procedures to minimize this risk and will reassess RTO as the operational team grows.

2. Critical Systems Inventory

System	Provider	Criticality	Backup Strategy
Application Server	Hetzner	Critical	Daily encrypted backups
Database	Supabase	Critical	Supabase automated backups (daily)
Anthropic API	Anthropic	Critical	Graceful degradation message
Code Repository	GitHub	High	Local mirrors + Git history
DNS	Registrar	High	Document nameserver config
SSL Certificates	Let's Encrypt	High	Auto-renewal + manual backup

3. Disruption Scenarios

3.1 Server Failure (Hetzner)

1. Detect failure via monitoring alerts. 2. Provision a new Hetzner server instance. 3. Restore application from the most recent encrypted backup. 4. Point application to existing Supabase database (data is preserved independently). 5. Update DNS if IP changed. 6. Run smoke test. 7. Notify affected clients if outage > 8 hours.

3.2 Database Failure (Supabase)

1. Detect via API error responses or monitoring. 2. Contact Supabase support and assess scope. 3. Restore from Supabase's automated point-in-time recovery if data loss has occurred. 4. Display user-facing maintenance message during recovery.

3.3 Anthropic API Outage

1. Detect via API error responses. 2. Display: "AI analysis temporarily unavailable. Document upload and report viewing remain functional." 3. Queue pending analysis requests for retry when available.

3.4 Founder / Key Person Unavailable

Alpine acknowledges that the Founder is currently the primary operational contact. Mitigations in place:

- All recovery procedures documented in this manual to enable handoff.
- Infrastructure credentials stored in encrypted password manager accessible to designated backup contact.
- Supabase data is independently accessible and not dependent on Hetzner server availability.
- Plan: address single-point-of-failure risk with operations hire as team grows.

4. Communication Plan

If a service disruption exceeds 8 hours, Alpine will notify all active clients via email with: (1) description of the issue, (2) estimated time to resolution, (3) any actions required by the client, and (4) a follow-up upon resolution.

Appendix L: Data Processing Agreement

Template: To be executed between Alpine Due Diligence Inc. ("Processor") and each client ("Controller").

1. Scope of Processing

The Processor will process personal data and confidential business data solely for the purpose of providing the operational due diligence analysis services described in the Service Agreement. Processing activities include: document ingestion, AI-powered analysis, report generation, and secure storage during the engagement.

2. Categories of Data

- Fund documentation (PPMs, DDQs, audited financials, organizational charts)
- Regulatory filing data (SEC registrations, ADV forms)
- Business correspondence related to fund operations
- Any personal data contained within the above documents

3. Sub-Processors

Sub-Processor	Purpose	Data Handled	Safeguards
Anthropic	AI analysis API	Document text (transient)	DPA + ZDR + no training
Hetzner	App server	Application layer	ISO 27001 + DPA
Supabase	Database & storage	All persistent data (enc.)	DPA + AES-256
Resend	Email delivery	Email content in transit	DPA

4. Security Obligations

The Processor will implement and maintain the technical and organizational security measures described in Appendix C and Appendix D, including encryption at rest (AES-256) and in transit (TLS 1.3), role-based access controls, and audit logging.

5. Breach Notification

In the event of a personal data breach, the Processor will notify the Controller within 72 hours of becoming aware of the breach, including: (a) nature of the breach, (b) categories and approximate number of records affected, (c) likely consequences, and (d) measures taken or proposed.

6. Data Deletion

Upon termination of the Service Agreement, the Processor will delete all Controller data within 30 days and provide written confirmation.

7. Signatures

Authorized Signatory: Alpine Due Diligence Inc. (Processor)

Date: _____

Authorized Signatory: Client Organization (Controller)

Date: _____

Appendix M: Risk Assessment

[v2.0 Update: Supabase data exposure risk added; founder risk mitigations updated.]

1. Risk Register

Risk	Likelihood	Impact	Controls	Residual
Unauthorized data access	Medium	High	Auth + RBAC + audit + encryption	Low
API data exposure	Low	High	Commercial Terms + DPA + ZDR	Very Low
Server compromise (Hetzner)	Low	High	Firewall + SSH + fail2ban + enc.	Low
Supabase data exposure	Low	High	Supabase DPA + AES-256 + RBAC	Low
Backup failure / data loss	Low	Medium	Daily enc. backups + quarterly test	Low
Founder unavailable	Medium	High	BCP + documented procedures + team	Medium
Credential theft (phishing)	Medium	High	Strong passwords + lockout + MFA	Medium
Supply chain (vendor breach)	Low	High	Vendor DPAs + ZDR + annual review	Low
Insider threat	Low	High	Audit logging + least privilege	Low
Denial of service	Low	Medium	Rate limiting + Cloudflare DDoS	Low
Regulatory non-compliance	Low	Medium	This policy manual + SOC 2 roadmap	Low

2. Risk Mitigation Priorities

High Priority (Address Immediately)

- Founder / key person single point of failure: Mitigate by documenting all procedures, storing credentials securely in a shared password manager, and expanding the operational team.
- Credential theft: Enforce multi-factor authentication (MFA) for all administrative access.

Medium Priority (Address Within 90 Days)

- Penetration testing: Engage an external security firm.
- Formalize backup restoration testing with documented results.
- Complete Supabase DPA review and confirm data residency region.

Ongoing

- Maintain all current controls as documented in this manual.
- Review this risk assessment quarterly and update as the threat landscape evolves.

Appendix N: Policy Acknowledgment Form

REQUIRED: All Employees, Contractors & Authorized Users

Each individual with access to Alpine systems must sign this form and return it to:
azhang@alpinedd.com
within 5 business days of receiving access.

Acknowledgment

By signing below, I acknowledge and confirm the following:

1. I have received, read, and understood the Alpine Due Diligence Compliance Policy Manual (Version 2.0, dated April 27, 2026), including all appendices listed herein.
2. I understand the policies, procedures, and standards described in this manual, including the Information Security Policy (Appendix D), Data Classification & Handling Policy (Appendix E), Incident Response Plan (Appendix G), Acceptable Use Policy (Appendix I), and all other referenced policies.
3. I agree to comply with all policies contained in this manual in the performance of my duties.
4. I understand that I must report any suspected or actual security incidents, policy violations, or unauthorized access immediately to the Security Lead at azhang@alpinedd.com.
5. I understand that failure to comply with these policies may result in disciplinary action, including suspension or termination of system access, termination of employment or contract, and/or legal action.
6. I understand that I will be required to re-acknowledge this manual annually or whenever a material revision is published.

Signature

Full Name (Printed):

Title / Role:

Date:

Signature:

Submission Instructions

- Print this page, sign and date it, then scan or photograph clearly.
- Email the signed copy to azhang@alpinedd.com with subject line: "Policy Acknowledgment - [Your Full Name]"

- Retain a personal copy for your records.